Outils de Monitoring Reseau:

Splunk - Découverte et Enumération:

Splunk est outils d'analyse de logs utiliser pour connecter analyser et visua
ser des données, c'est un outil très répendu notamment dans les grandes entrep
ses il possède peux de vulnérabilités connues. Le principal point de mire de sp
unk reste une authentification faible ou nulle
Il s'exécute souvent avec des privileges élèves.
Il s'exécute par default sur le port 8000 et anciennement ses credentials par dé
ault etaient admin / changeme
La version d'essai entreprise se transforme en version gratuite au bout de 60
rs sans authentifications.
Splunk dispose de nombreux moyen d'exécuter du code sur le server (appli Djan
coté Server, point de terminaison REST, entrée scripté, scripts d'alertes)

Attaquer Splunk:

On peux donc obtenir une RCE sur Splunk en créant une application personn
isé pour exécuter des scripts, python Powershell ou Bash
On peu trouver plusieurs application Splunk backdoor toute faites sur github s
on voici leur schema global:

splunk_shell/
bin => contient les scripts que l'on pourrait d'exécuter (on peu y mettre un
default
inputs.conf => indique a splunk quel scripts exécuter et dans quelles co
ditions (exemple tout les 10 secondes)

Ensuite on crée une archive tar de tout ce dossier (splunk_shell) et on l'install de
"Install app from files".
⚠ Dans certains cas il peux etre possible d'obtenir une RCE sur les Hosts via les
versals forwarders

PRTG - Network Monitor:

PRTG Network Monitor est un logiciel de surveillance de réseau sans agen
qui permet de superviser la bande passante, la disponibilité et de collecter des
statistiques sur des appareils comme les routeurs serveurs etc
Il fonctionne sur les pages ports web courant (par default)
La bannière du service revèle souvent sa version ce qui peux s'avérer crucial p
ur un audit de vulnérabilités connues
Notons l'existences de credentials par default prtgadmin / prtgadmin

- Parmi les vulnérabilités connues on a CVE-2018-9276 une injection
commande authentifié qui affecte les versions < 18.2.39.
L'attaque consiste a créer une nouvelle "notification" qui utilise la fonctionnalité
EXECUTE PROGRAM. La commande malveillante est insérée dans le champ para
mètre. Le script Demo exe notification-outfile.ps1 est utilisé pour exécuter la com
ande, en cliquant sur le bouton test de la notification nouvellement créé, l'exécuti
est aveugle l'on peu par exemple créé un nouvel user admin et se loggen ensuite sur
Windows si il est activé

Type Exemple de payload injecté dans le champ parameter:
; test.txt; net user /add hol Pol123pa$$ /add; net localgroup administrators ho
/add

Evidemment on a plusieurs blogs sur le web expliquant cette vulnérabilités...